

Metodología de Trabajo

Evaluación de seguridad del sistema “Centro Hogar” desde los seis servicios de LoBeMo
LoBeMo Seguridad Informática — Trabajo Final Integrador

1. Objetivo del documento

Este documento define cómo LoBeMo abordó el análisis del sistema “Centro Hogar” (Sistema de Gestión de Ventas para una mueblería, desarrollado por otro grupo de la Tecnicatura en Programación de UTN FRT), tomado como caso de estudio ficticio. La idea es que el análisis no sea un ejercicio arbitrario, sino que siga una metodología explícita y trazable, tal como lo haría una consultora real antes de entregar un informe a un cliente.

El sistema Centro Hogar no tiene relación con LoBeMo ni fue desarrollado por el mismo grupo: se lo trata como si fuera un cliente que contrató los seis servicios de la empresa.

2. Encuadre metodológico

Un punto central que se deja explícito desde el inicio: este análisis se realiza exclusivamente sobre documentación y código fuente entregados por el otro grupo (Carpeta_Final.pdf, Centro_Hogar.docx, DOCUMENTACION.md, y el repositorio de código). En ningún momento se ejecutan herramientas de ataque, escaneo activo ni pruebas de intrusión reales contra un sistema en producción, porque:

- No existe una autorización formal (Rules of Engagement) del otro grupo para actuar como si fueran su proveedor de seguridad, ya que el caso es un ejercicio académico y no un contrato real.
- En la industria real, actuar sobre un sistema ajeno sin autorización explícita por escrito constituye un delito informático, independientemente de la intención — este mismo principio se traslada al ejercicio académico para que sea metodológicamente correcto.
- El objetivo pedagógico del TFI es demostrar cómo LoBeMo organiza y gestiona sus servicios, no producir un pentest técnico real.

Por eso, cada uno de los seis servicios se aplica bajo un enfoque de análisis documental y estático (revisión de arquitectura, código, configuración y reglas de negocio), y en los casos donde la práctica real exige interacción en vivo con el sistema (Pentesting, Análisis Forense), el informe lo señala expresamente como escenario simulado o hallazgo potencial, nunca como una explotación o incidente confirmado.

3. Metodología por servicio

Para que el análisis no sea improvisado, cada servicio se apoya en un estándar o marco de referencia real de la industria, adaptado al alcance documental de este trabajo.

3.1. Auditoría de Seguridad

Objetivo	Evaluar de forma integral la arquitectura, los procesos y las reglas de negocio documentadas, identificando debilidades estructurales antes de que se traduzcan en incidentes.
Fuentes utilizadas	Carpeta_Final.pdf (arquitectura backend/frontend, modelo entidad-relación, requerimientos funcionales y no funcionales, reglas de negocio) y DOCUMENTACION.md.
Marco de referencia	Enfoque inspirado en ISO/IEC 27001 (control de gestión) y en el checklist de auditoría de aplicaciones de OWASP ASVS (Application Security Verification Standard), usados como guía de qué categorías revisar, no como certificación formal.
Técnica aplicada	Revisión sistemática de cada componente documentado (autenticación, manejo de sesiones, roles, validación de datos, gestión de dependencias) contra las categorías de control de los marcos citados.
Entregable	Matriz de hallazgos por categoría, con severidad (crítica / alta / media / baja) y recomendación asociada.
Limitación declarada	Es una auditoría documental: se basa en lo que el sistema declara hacer, no en pruebas ejecutadas sobre el sistema en funcionamiento.

3.2. Pentesting Web

Objetivo	Identificar posibles vectores de ataque explotables en la aplicación web, a partir de patrones conocidos de vulnerabilidad.
Fuentes utilizadas	Código fuente disponible (rutas, controladores, middlewares) y stack tecnológico declarado (React 19, Node.js, Express, MySQL, JWT, bcryptjs, Helmet, CORS, express-rate-limit, Zod).
Marco de referencia	OWASP Top 10 (2021) como catálogo de referencia para clasificar los hallazgos, y OWASP Testing Guide como estructura de análisis.
Técnica aplicada	Análisis estático de código (SAST manual): búsqueda de patrones vulnerables — inyección, manejo inseguro de JWT, falta de sanitización, exposición de datos sensibles, configuración de CORS y rate-limiting — sin ejecutar exploits reales.
Entregable	Listado de vectores potenciales, cada uno mapeado a una categoría del OWASP Top 10, con una explicación de por qué sería explotable si se confirmara en tiempo de ejecución.
Limitación declarada	No se realiza pentesting activo (sin explotación real ni tráfico contra el sistema en producción). Los hallazgos se presentan como “vectores potenciales identificados por análisis estático”, no como vulnerabilidades confirmadas.

3.3. Hardening de Sistemas

Objetivo	Evaluar el nivel de fortalecimiento de la configuración del sistema frente a buenas prácticas reconocidas.
Fuentes utilizadas	Configuración declarada en el código y la documentación: uso de Helmet, CORS, express-rate-limit, variables de entorno, gestión de contraseñas con bcryptjs.
Marco de referencia	CIS Benchmarks (Center for Internet Security) como referencia general de hardening, adaptado a nivel de aplicación web dado que no hay acceso a los servidores reales.
Técnica aplicada	Comparación punto por punto entre lo que el sistema implementa (según el código) y las recomendaciones estándar para cada capa (cabeceras HTTP, límites de tasa, políticas de contraseñas, gestión de secretos).
Entregable	Checklist de cumplimiento con estado (implementado / parcial / ausente) por cada control revisado.
Limitación declarada	Se evalúa la configuración declarada en el código, no la configuración real del servidor o infraestructura de despliegue, a la cual no se tiene acceso.

3.4. Análisis Forense

Objetivo	Determinar la capacidad del sistema para sostener una investigación digital si ocurriera un incidente de seguridad.
Fuentes utilizadas	Documentación de logging, manejo de sesiones y trazabilidad descrita en Carpeta_Final.pdf y DOCUMENTACION.md.
Marco de referencia	Principios generales de NIST SP 800-86 (Guide to Integrating Forensic Techniques into Incident Response), usados como criterio de qué capacidades debería tener un sistema para ser “forense-friendly”.
Técnica aplicada	Evaluación de capacidad, no investigación de un incidente real: se revisa si el sistema genera y conserva evidencia suficiente (logs de acceso, timestamps, registro de cambios) para reconstruir un eventual incidente.
Entregable	Informe de brechas de trazabilidad, con un escenario hipotético (“si ocurriera un acceso no autorizado a la base de clientes, ¿qué evidencia permitiría reconstruirlo?”) a modo ilustrativo.
Limitación declarada	No hay un incidente real ni evidencia forense recolectada: es un análisis de preparación (“forensic readiness”) sobre un escenario simulado.

3.5. Capacitaciones

Objetivo	Detectar brechas de conocimiento del equipo de desarrollo reflejadas en decisiones de diseño y código, para proponer un plan de formación.
Fuentes utilizadas	Patrones observados en el código y en las decisiones de arquitectura documentadas.
Marco de referencia	Marco de referencia: OWASP Top 10 y buenas prácticas de “Secure Coding”, usados para relacionar cada hallazgo técnico con un tema de capacitación concreto.
Técnica aplicada	Mapeo de cada debilidad encontrada en los servicios anteriores hacia una necesidad de formación específica (por ejemplo: manejo de JWT → capacitación en autenticación segura).
Entregable	Programa de capacitación propuesto: temas, público objetivo (equipo técnico / no técnico) y prioridad.
Limitación declarada	Es una propuesta basada en indicios del código, no una evaluación directa de las personas del equipo de desarrollo original.

3.6. Consultoría Estratégica

Objetivo	Brindar una mirada de cumplimiento normativo y una hoja de ruta de mejora continua de seguridad para el negocio.
Fuentes utilizadas	Resumen ejecutivo, objetivos y contexto de negocio documentados en Carpeta_Final.pdf.
Marco de referencia	Referencias generales de cumplimiento aplicables a un e-commerce/sistema de ventas en Argentina (Ley de Protección de Datos Personales 25.326) como marco de contexto normativo.
Técnica aplicada	Análisis de brecha entre el estado actual documentado y una hoja de ruta de mejora en etapas (corto, mediano y largo plazo).
Entregable	Documento de recomendaciones estratégicas priorizadas, alineado con el negocio de la mueblería (no solo con lo técnico).
Limitación declarada	No constituye asesoramiento legal formal; es una orientación general de cumplimiento a nivel de buenas prácticas.

4. Estructura del informe final

El informe de evaluación integral se organiza replicando este mismo orden metodológico, para que quede trazado con claridad de dónde sale cada conclusión:

- Resumen ejecutivo del caso Centro Hogar.
- Alcance y encuadre metodológico (esta sección, resumida).
- Hallazgos por servicio (los seis bloques desarrollados arriba).
- Matriz consolidada de riesgos, con severidad y prioridad de resolución.
- Conclusiones y hoja de ruta recomendada para el cliente.

5. Nota sobre el alcance académico

Este trabajo fue realizado por un grupo sin formación previa en ciberseguridad, en el marco de la materia Administración de Sistemas de Información. El foco metodológico no es demostrar dominio técnico de explotación de vulnerabilidades, sino mostrar cómo una empresa de ciberseguridad organiza, documenta y comunica su trabajo frente a un cliente — que es, en definitiva, el objetivo de gestión que plantea la materia.